

D2C Brand DPDPA Starter Checklist

Your D2C brand doesn't just sell products — it tracks, messages and retargets customers every day. Work through these ten areas to bring marketing consent, tracking, vendor sharing, customer data and retention under DPDPA-ready control.

Customer Data

Marketing Consent

WhatsApp

SMS

Meta Pixel

Retargeting

Vendors

Unsubscribe

Health Data

Retention

How to use this: tick what you already do, and turn the unticked boxes into your next actions. Start with marketing consent, unsubscribe/preferences and tracking disclosure — they remove the most risk for the least effort.

1 Customer data collection & minimisation

- ☐ List the customer data you collect at checkout, in accounts, in support and in marketing.
- ☐ Collect only what you actually use — drop fields you don't need.
- ☐ Avoid reusing customer lists exported from marketplaces for your own marketing without consent.
- ☐ Keep one primary customer record so you always know what you hold and where.
- ☐ Show a clear privacy notice at the point you collect data — not buried in the footer.

2 Marketing consent (WhatsApp / SMS / email)

- ☐ Capture a clear, unticked opt-in before any promotional WhatsApp, SMS or email.
- ☐ Keep marketing consent separate from order acceptance — a purchase is not consent.
- ☐ Use a separate opt-in for each channel (email, SMS, WhatsApp), not one bundled box.
- ☐ Record how and when each customer opted in, as evidence.
- ☐ Re-consent any list built from bought, scraped or pre-ticked sources.

3 Unsubscribe & preference management

- ☐ Offer a one-click opt-out and honour it across every channel, not just email.
- ☐ Maintain a single customer preference the customer can view and change.
- ☐ Stop WhatsApp/SMS marketing the moment a customer opts out, everywhere.
- ☐ Confirm opt-out requests and apply them within a defined timeline.
- ☐ Don't rely on manual 'remove me when they ask' handling.

4 Tracking, pixels & adtech disclosure

- ☐ Inventory every pixel, tag and script on your store — Meta, Google, TikTok, recording tools.
- ☐ Remove any agency-managed or unknown scripts you can't account for.
- ☐ Disclose all tracking tools in your privacy notice.
- ☐ Add a consent mechanism before non-essential / remarketing tracking fires.
- ☐ Review the tag list whenever an agency or app changes your storefront.

5 Lifecycle marketing & profiling

- ☐ List your automated flows — cart abandonment, win-back, recommendations, loyalty.
- ☐ Disclose customer segmentation and lookalike-audience use, and get consent where needed.
- ☐ Treat personalisation that profiles customers as a purpose to disclose, not a default.
- ☐ Make sure lifecycle messages respect the customer's opt-out state.
- ☐ Avoid sharing customer data with ad platforms beyond what the customer agreed to.

6 Vendor & processor management

- ☐ List every vendor that touches customer data — payment, logistics, CRM, email/SMS, plugins, agency.
- ☐ Put data-processing terms in place with each vendor (a DPA).
- ☐ Vet third-party Shopify/WooCommerce plugins before installing — they can read customer data.
- ☐ Confirm what your marketing agency stores and where, if it handles your data.
- ☐ Remove vendors and apps you no longer use, and revoke their access.

7 Store-admin & account access

- ☐ Use role-based access for your store admin, marketing tools and exports.
- ☐ Avoid shared logins — give each team member their own account.
- ☐ Turn on MFA for every account that can open customer data.
- ☐ Revoke ex-staff and ex-agency access the day the relationship ends.
- ☐ Review who can export the customer list at least twice a year.

8 Sensitive & health / body data

- ☐ Identify any skin, hair, body, health or wellness data you collect (beauty, fitness, food, wellness).
- ☐ Treat it as sensitive — stronger consent, tighter access, clear purpose.
- ☐ Avoid using health/body data for ad targeting or lookalikes without explicit consent.
- ☐ Limit who inside the team can see sensitive customer attributes.
- ☐ Delete sensitive data you no longer need for the stated purpose.

9 Customer rights (access / correction / deletion)

- ☐ Publish a simple way for customers to access, correct or delete their data.
- ☐ Define who handles requests and a target response timeline.
- ☐ Verify identity before acting on a request.
- ☐ Delete across store, marketing tools, exports and backups — not just the primary record.
- ☐ Log each request and what you did, as evidence of compliance.

10 Retention & breach readiness

- ☐ Set how long you keep customer data, and delete inactive records on a schedule.
- ☐ Don't keep all customer data indefinitely by default.
- ☐ Know which vendors hold copies of your customer data.
- ☐ Have a basic breach-response plan: who to tell, how fast, what to record.
- ☐ Write retention rules down so the whole team applies them consistently.